

Hi, we will explain the solution of portswigger lab : Lab: Broken brute-force protection, IP block
This is medium level lab btw In the Authentication Topic Our Goal here is to brute force carlos account and get his password

Lab: Broken brute-force protection, IP block

PRACTITIONER



LAB



Solved



This lab is vulnerable due to a logic flaw in its password brute-force protection. To solve the lab, brute-force the victim's password, then log in and access their account page.

- Your credentials: `wiener:peter`
- Victim's username: `carlos`
- Candidate passwords



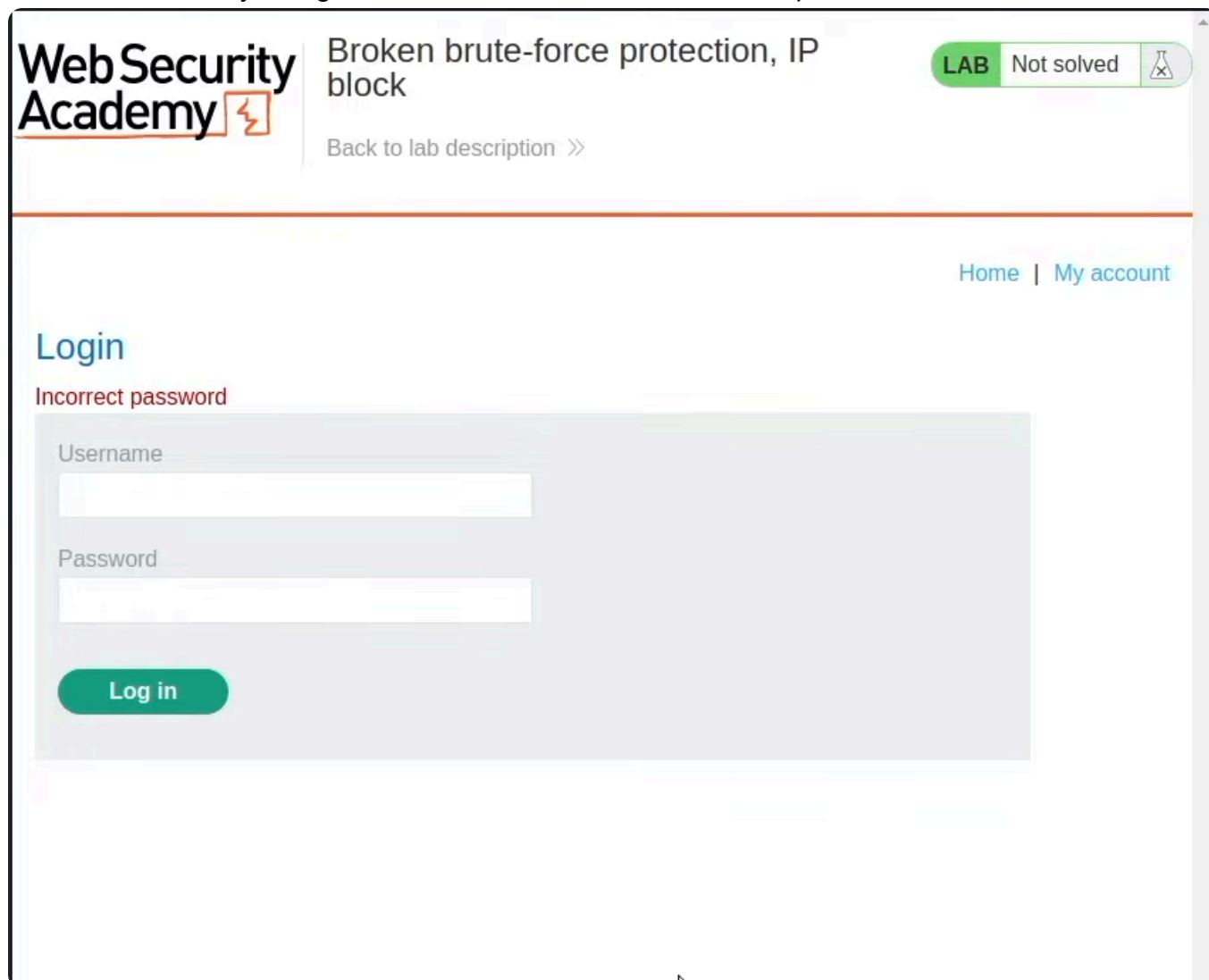
Hint



ACCESS THE LAB

first of all as we see they gave us a candidate passwords wordlist and also valid username and password so we can login with it

first of all we will try to login with valid username and incorrect password :



The screenshot shows the Web Security Academy interface. At the top left is the logo. To its right is the lab title 'Broken brute-force protection, IP block' and a status bar with 'LAB', 'Not solved', and a flask icon. Below the title is a link 'Back to lab description >>'. On the right side, there are links for 'Home' and 'My account'. The main section is titled 'Login' and displays a red error message 'Incorrect password'. Below this is a login form with two input fields: 'Username' and 'Password'. The 'Username' field contains the text 'root'. Below the fields is a green 'Log in' button.

we got incorrect password which is also vulnerability that show us the valid usernames in the website anyway let's send the request to the reeater in burpsuite:

The screenshot shows a web browser's developer tools with the 'Request' and 'Response' tabs. The 'Request' tab is active, showing a POST request to `https://0a6c00ab03906a32c175e4ef00010037.web-security-academy.net/login`. The request body is `username=wiener&password=test`. The 'Response' tab is also active, showing a 403 Forbidden status with the message 'Broken brute-force protection, IP block'. The response body shows a login form with an error message: 'You have made too many incorrect login attempts. Please try again in 1 minute(s)'.

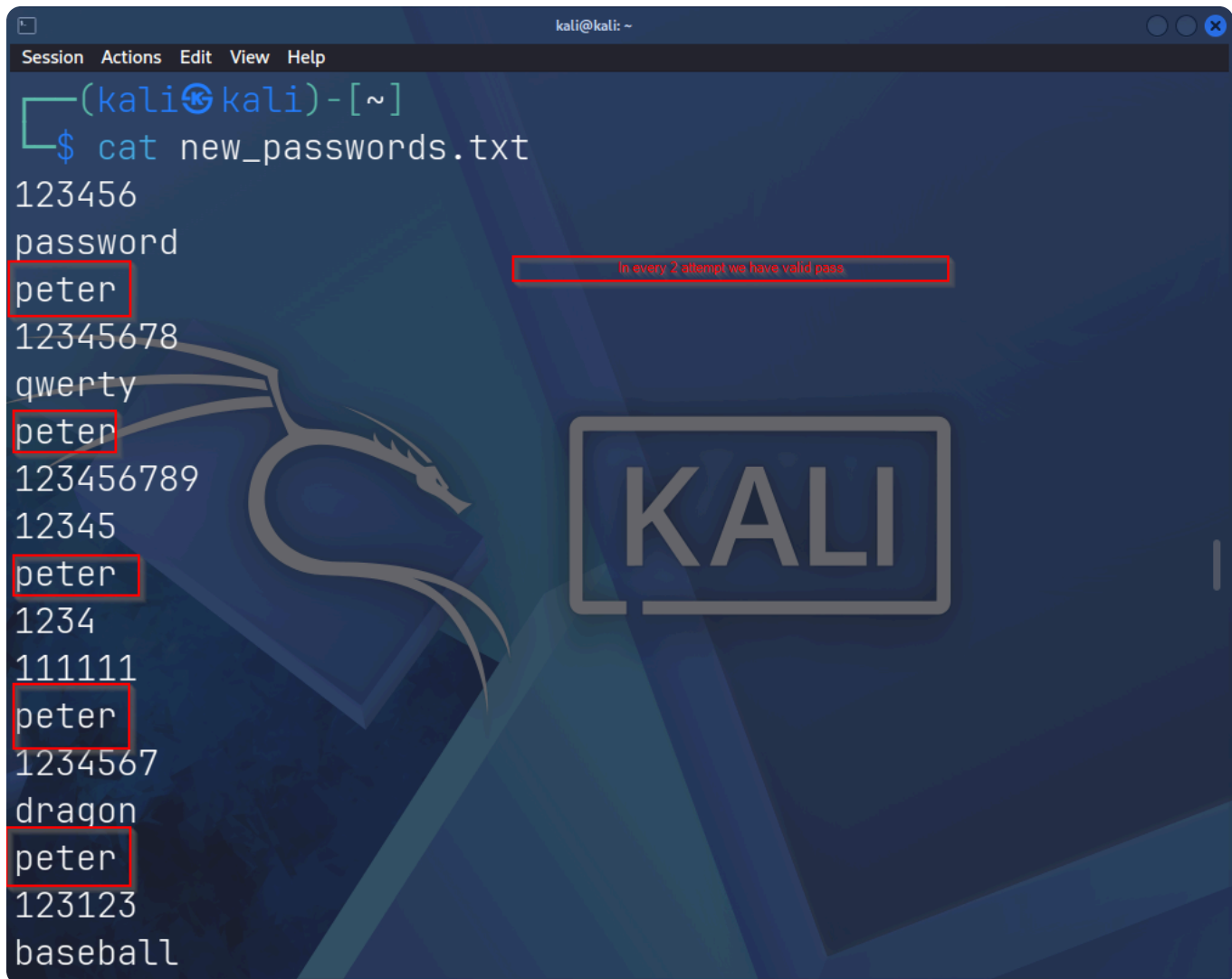
We notice if we send the request 3 times we will get an ip Block which say please try again after in 1 minute but what if we try to login with the vailed username and vailed password after the third attempt? lockily we got 302 redirect which mean in the third attempt if u tried to login with a vailed account and ip block will be restarted :) this is vulnerability that we can take advantage of it and brute force password of any username in the website

now we now if we login in our vaild account in the third time we will reset the block so we can make python script that will write wordlist that has our username and password combined with the password list that they gave us and login in every 2 attempt with vaild credntioals

we can use the lab.py script which will create username list that has wiener username after every 2 attempt Like THIS:

```
kali@kali: ~  
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ cat new_usernames.txt  
carlos  
carlos  
wiener  
carlos  
carlos  
wiener  
carlos  
carlos  
wiener  
carlos  
carlos  
wiener  
carlos  
carlos  
wiener
```

and The Password list should be Like THIS:



A terminal window titled 'kali@kali: ~' with a menu bar (Session, Actions, Edit, View, Help). The prompt is '(kali@kali)-[~]'. The command '\$ cat new_passwords.txt' has been executed, displaying a list of passwords: 123456, password, peter, 12345678, qwerty, peter, 123456789, 12345, peter, 1234, 111111, peter, 1234567, dragon, peter, 123123, and baseball. The word 'peter' is highlighted with a red box in each of its five occurrences. A red-bordered box on the right contains the text 'In every 2 attempt we have valid pass'. The background features a Kali Linux dragon logo and the word 'KALI' in a large box.

```
(kali@kali)-[~]  
$ cat new_passwords.txt  
123456  
password  
peter  
12345678  
qwerty  
peter  
123456789  
12345  
peter  
1234  
111111  
peter  
1234567  
dragon  
peter  
123123  
baseball
```

In every 2 attempt we have valid pass

now we can use this wordlists that we generated in burp suite intruder and brute force carlos account without getting block :)

now after sending the login request to the intruder we added the username and password as marked

Menu: Burp Project Intruder Repeater Window Help

Sub-menu: Dashboard Target Proxy **Intruder** Repeater Sequencer Decoder Comparer Logger Extender

Project options User options Learn

1 x 6 x +

Positions Payloads Resource Pool Options

Choose an attack type Start attack

Attack type:

Payload Positions

Configure the positions where payloads will be inserted, they can be added into the target as well as the base request.

Target: ☒ Update Host header to match target

Add \$
Clear \$
Auto \$
Refresh

```
8 Sec-Ch-Ua-Platform: "Linux"
9 Upgrade-Insecure-Requests: 1
10 Origin: https://0a6c00ab03906a32c175e4ef00010037.web-security-academy.net
11 Content-Type: application/x-www-form-urlencoded
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/105.0.5195.102 Safari/537.36
13 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,i
  mage/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Referer:
  https://0a6c00ab03906a32c175e4ef00010037.web-security-academy.net/login
19 Accept-Encoding: gzip, deflate
20 Accept-Language: en-US,en;q=0.9
21 Connection: close
22
23 username=$carlos$password=$peter$
```

0 matches Clear

2 payload positions Length: 1018

now we will change the attack type to PitchFork

Choose an attack type Start attack

Attack type:

now we need to paste our new username and password lists that we got from our script in the payload lets past our password list:

DashboardTargetProxyIntruderRepeaterSequencerDecoderComparerLoggerExtender

Project optionsUser optionsLearn

1 ×6 ×+

PositionsPayloadsResource PoolOptions

?

Payload Sets

Start attack

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.

Payload set:2

Payload count: 150

Payload type:Simple list

Request count: 150

?

Payload Options [Simple list]

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load ...

Remove

Clear

Deduplicate

Add

Add from list ...

peter

123456

password

peter

12345678

qwerty

peter

Enter a new item

?

Payload Processing

You can define rules to perform various processing tasks on each payload before it is used.

Add

Edit

Remove

Up

Down

...

Rule

now lets past our username list in the set 1

Dashboard Target Proxy **Intruder** Repeater Sequencer Decoder Comparer Logger Extender

Project options User options Learn

1 x 6 x +

Positions **Payloads** Resource Pool Options

Start attack

Payload Sets

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.

Payload set: 1 Payload count: 150

Payload type: Simple list Request count: 0

Payload Options [Simple list]

This payload type lets you configure a simple list of strings that are used as payloads.

Paste Load ... Remove Clear Deduplicate Add Add from list ...

wiener
carlos
carlos
wiener
carlos
carlos
wiener

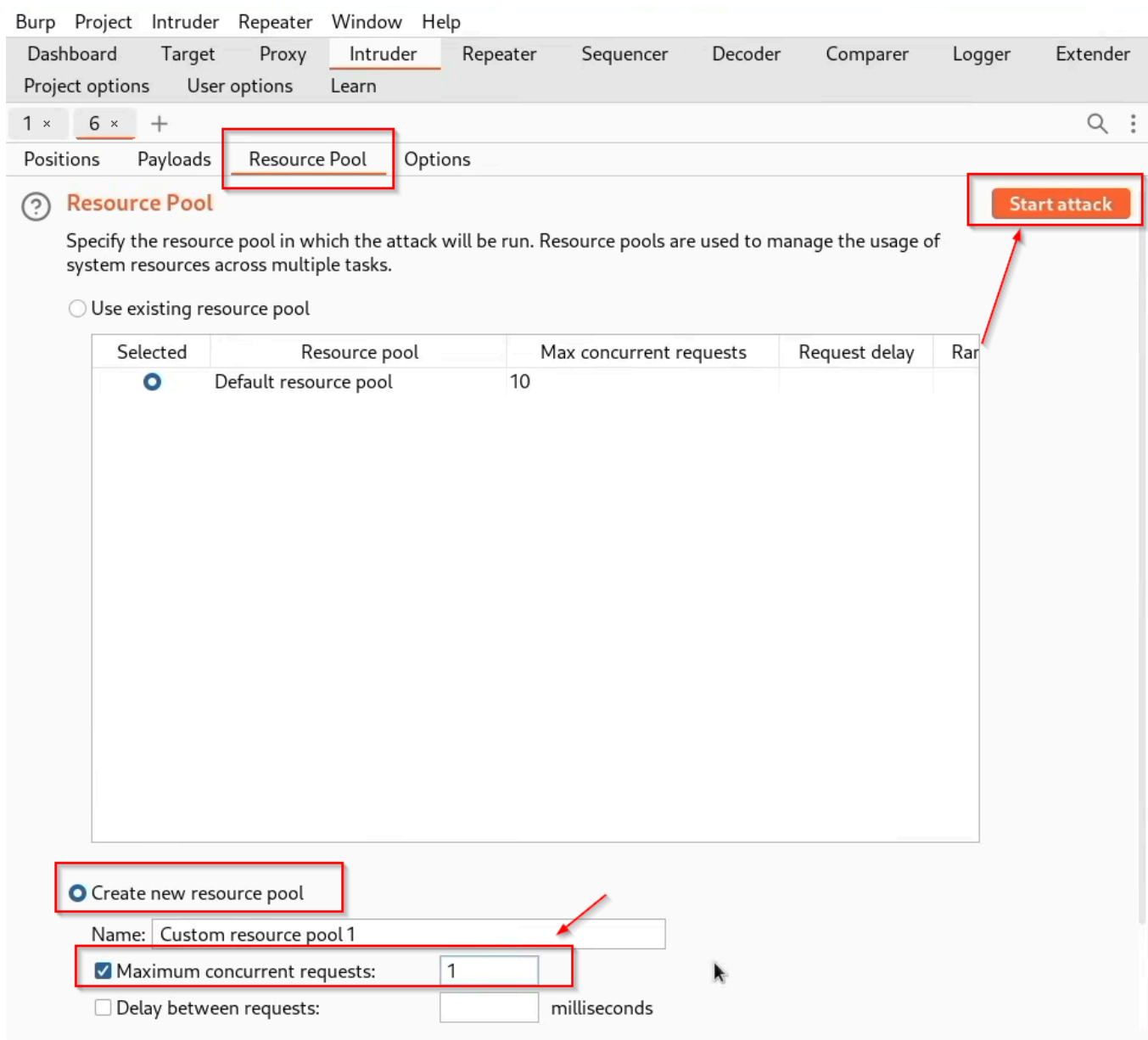
Enter a new item

Payload Processing

You can define rules to perform various processing tasks on each payload before it is used.

Enabled	Rule

now the last thing before running the attack is to set the maximum trying per second to 1 insted of 10 which is default in Burp



Now u can start the attack after the attack finish u can now search in the response for 302 redirect of carlos account and u can know what is his password Note:ignore all carlos 200 ok and wiener 302 redirect

Thanks for reading and sorry for spelling mistake cuz i write this quickly

kaliman